

Git Repository Security & Secret Scanning Guide

Purpose

Explain the security tools used to detect secrets and vulnerabilities in source code and CI/CD pipelines.

Context

Developers can accidentally expose passwords, API keys, and tokens in code. Security scanning tools help find and prevent these issues before deployment.

Real-World Example

A developer commits an AWS key to Git. The security tools detect and block it before the application reaches production.

Problem

- Hardcoded secrets in code
- Security vulnerabilities
- Risk of data breaches
- No automated security checks
- Lack of automated security validation in CI/CD pipelines.
- Increased risk of data breaches, compliance violations, and financial loss.

Solution

Use tools to automatically scan code, detect secrets, and identify vulnerabilities during development and CI/CD.

Business Outcome

- Improve application security
- Prevent secret leaks
- Reduce security risks
- Meet compliance requirements
- Deliver secure software faster
- Accelerates secure software delivery through automated DevSecOps practices.
- Strengthens customer trust and organizational security posture.
- Reduces incident response and remediation costs.

Note: Automated security scanning is a key DevSecOps practice that helps identify and fix security issues before production.

1 Betterleaks

It is a fast secret scanning tool that scans repositories and source code for exposed API keys, passwords, tokens, credentials, and certificates.

Why: Helps quickly identify sensitive information accidentally stored in code.

betterleaks dir . # Scan current directory

betterleaks dir . -v # Scan current directory with verbose output

betterleaks git . -v # Scan Git repository with verbose output

```
ubuntu@ip-172-31-36-199:~/COTASK$ betterleaks git . -v
o
o
o betterleaks dev
-mongodb-connection-string-o
40 | MONGO_URI      = f"mongodb://{MONGO_USER}:{MONGO_PASS}@127.0.0.1:27017/admin"
    |              ~~~~~
attributes:
git.author_email ..... 78133546+0000sai@users.noreply.github.com
git.author_name ..... vishnu sai
git.date ..... 2025-09-29T15:18:56Z
git.message ..... Create cleanupscripts3backup.py
git.platform ..... github
git.remote_url ..... https://github.com/0000sai/COTASK
git.sha ..... cb03f9de062769ede383b669cc66b363bcb4e7a5
path ..... Script/phy/cleanupscripts3backup.py
resource ..... git.patch_content
url ..... https://github.com/0000sai/COTASK/blob/cb03f9de062769ede383b669cc66b363bcb4e7a5/Script/phy/cleanupscripts3backup.py#L40
o
-mongodb-connection-string-o
40 | MONGO_URI      = f"mongodb://{MONGO_USER}:{MONGO_PASS}@127.0.0.1:27017/admin"
    |              ~~~~~
attributes:
git.author_email ..... 78133546+0000sai@users.noreply.github.com
git.author_name ..... vishnu sai
git.date ..... 2025-09-29T15:22:59Z
git.message ..... Create DBcleanup3.py
git.platform ..... github
git.remote_url ..... https://github.com/0000sai/COTASK
git.sha ..... a7255b9b86d3569624d71125469ce1414cc2d80d
path ..... Script/phy/Cleanupscript/DBcleanup3.py
resource ..... git.patch_content
url ..... https://github.com/0000sai/COTASK/blob/a7255b9b86d3569624d71125469ce1414cc2d80d/Script/phy/Cleanupscript/DBcleanup3.py#L40
o
-generic-api-key-o
```

```
-generic-api-key-o
7 | password      = "jvasccqte7yibxwyst2i2db"
  |              ~~~~~
attributes:
git.author_email ..... 78133546+0000sai@users.noreply.github.com
git.author_name ..... 0000sai
git.date ..... 2024-08-16T12:03:40Z
git.message ..... iam RDS, lamda ,EC2
git.platform ..... github
git.remote_url ..... https://github.com/0000sai/COTASK
git.sha ..... 17f0efd70493cb29b8a261654491c4b5109b39cd
path ..... AWS EC2,Lamda,RDS,IAM/RDS/terraform.tfvars
resource ..... git.patch_content
url ..... https://github.com/0000sai/COTASK/blob/17f0efd70493cb29b8a261654491c4b5109b39cd/AWS%20EC2,Lamda,RDS,IAM/RDS/terraform.tfvars#L7
o

5:16PM INF scanned ~7437392 bytes (7.44 MB) in 740ms
5:16PM WRN leaks found: 9
ubuntu@ip-172-31-36-199:~/COTASK$
```

```
ubuntu@ip-172-31-36-199:~/COTASK$ betterleaks dir . -v
```

```
o
o
•
o betterleaks dev
```

```
—mongodb-connection-string—o
```

```
40 | MONGO_URI      = f"mongodb://{MONGO_USER}:{MONGO_PASS}@127.0.0.1:27017/admin"
      | ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
```

```
attributes:
  path ..... ./Script/phy/cleanupscripts3backup.py
  resource ..... fs.content
```

```
—mongodb-connection-string—o
```

```
40 | MONGO_URI      = f"mongodb://{MONGO_USER}:{MONGO_PASS}@127.0.0.1:27017/admin"
      | ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
```

```
attributes:
  path ..... ./Script/phy/Cleanupscript/DBCleanup3.py
  resource ..... fs.content
```

```
—generic-api-key—o
```

```
2 | ...Parts":{"account_key":"yD051Cm7ud6VRLjHkjkiceT3ysgEYeDUn5SRC8jIU3PcNe/ZIoc1+90BfRAU13QkF6CLf...
      | ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^ (88 bytes)
```

```
attributes:
  path ..... ./trufflehog.json
  resource ..... fs.content
```

```
—generic-api-key—o
```

```
3 | ...Parts":{"account_key":"yD051Cm7ud6VRLjHkjkiceT3ysgEYeDUn5SRC8jIU3PcNe/ZIoc1+90BfRAU13QkF6CLf...
      | ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^ (88 bytes)
```

```
attributes:
  path ..... ./trufflehog.json
  resource ..... fs.content
```

2 gitleaks

What: An open-source secret scanner that checks source code, commits, and Git history for hardcoded credentials.

Why: Helps detect leaked passwords, API keys, and tokens.

gitleaks detect --source .

```
ubuntu@ip-172-31-36-199:~/COTASK$ ls
AWS_EC2,Lamda,RDS,IAM'
AWS-VPC-Landing-Zone-Terraform-main
AZ
CICD_BlueGreen_EC2-main
'Day 29 AzureDevOps-Part-2'
Docker-Compose-Examples-master
EC2podnewreagion.tf
EC2prod.tf
'EKS-Terraform-GitHub-Actions-master and Jenkins terraform module file and script'
'IAM user and polices'
LB.tf
Main.tf
Mastering-DevSecOps-Master
README.md
Redme.txt
Script
Terraform-for-AWS-master
TerraformScript-Co
azure-ci-cd-pipeline-main
backend.tf
blue-green-deploy-on-kubernetes-cluster-master
compose-dev-env-main
ubuntu@ip-172-31-36-199:~/COTASK$ gitleaks detect --source .

o
| \
|  o
o  oo
ooo
gitleaks

4:13PM INF 103 commits scanned.
4:13PM INF scan completed in 2.14s
4:13PM WRN leaks found: 5
```

gitleaks detect --source . --verbose

```

ubuntu@ip-172-31-36-199:~/COTASK$ gitleaks detect --source . --verbose

```

gitleaks

```

Finding:      password              = "jvasccqte7yibxwyst2i2db"
Secret:       jvasccqte7yibxwyst2i2db
RuleID:       generic-api-key
Entropy:      3.914866
File:         TerraformScript-Co/AWS/RDS/terraform.tfvars
Line:         7
Commit:       64ceb320f030840bc5633130c1f368cceb1e759a
Author:       0000sai
Email:        78133546+0000sai@users.noreply.github.com
Date:         2025-02-14T10:33:22Z
Fingerprint:  64ceb320f030840bc5633130c1f368cceb1e759a:TerraformScript-Co/AWS/RDS/terraform.tfvars:generic-api-key:7

Finding:      #projectKey: 'sqp_63da7bac31bd4496f2ee1170156659ea8c782c28'--NotNeeded
Secret:       sqp_63da7bac31bd4496f2ee1170156659ea8c782c28
RuleID:       generic-api-key
Entropy:      4.174674
File:         Mastering-DevSecOps-Master/Day 30 AzureDevOps-Part-3/azure-pipelines.yml
Line:         64
Commit:       dc3a39571642672b0985d61f26be2a913b21ccf9
Author:       0000sai
Email:        78133546+0000sai@users.noreply.github.com
Date:         2025-02-14T07:56:44Z
Fingerprint:  dc3a39571642672b0985d61f26be2a913b21ccf9:Mastering-DevSecOps-Master/Day 30 AzureDevOps-Part-3/azure-pipelines.yml:generic-api-key:64

Finding:      password: Mzk1MjgkdMnRnN0pi
-----
Secret:       Mzk1MjgkdMnRnN0pi
RuleID:       generic-api-key

```

gitleaks detect --source . --verbose

```

File:      kubernetes-yaml-templates-master/kubernetes-yaml-templates-master/pod/pod-secrets.yaml
Line:      18
Commit:    6272b1f6978fc0f0077c01ae58b34d431d0adab0
Author:    0000sai
Email:     78133546+0000sai@users.noreply.github.com
Date:      2024-12-26T11:48:13Z
Fingerprint: 6272b1f6978fc0f0077c01ae58b34d431d0adab0:kubernetes-yaml-templates-master/kubernetes-yaml-templates-master/pod/pod-secrets.yaml:generic-api-key:18

Finding:   "key": "roshan-mohammed-O_jdx6EeZRA-unsplash.jpg",
Secret:    roshan-mohammed-O_jdx6EeZRA-unsplash.jpg
RuleID:    generic-api-key
Entropy:   4.427567
File:      Terraform-for-AWS-master/Non-Modularized/Resize-Image-Using-LambdaFunction-S3-SNS/test-event.json
Line:      30
Commit:    378c08851ecd83b3a8fd95df593ae13a542b4f0c
Author:    0000sai
Email:     78133546+0000sai@users.noreply.github.com
Date:      2024-08-18T06:57:25Z
Fingerprint: 378c08851ecd83b3a8fd95df593ae13a542b4f0c:Terraform-for-AWS-master/Non-Modularized/Resize-Image-Using-LambdaFunction-S3-SNS/test-event.json:generic-api-key:3
0

Finding:   password = "jvasccgte7yibxwyst2i2db"
Secret:    jvasccgte7yibxwyst2i2db
RuleID:    generic-api-key
Entropy:   3.914866
File:      AWS_EC2,Lamda,RDS,IAM/RDS/terraform.tfvars
Line:      7
Commit:    17f0efd70493cb29b8a261654491c4b5109b39cd
Author:    0000sai
Email:     78133546+0000sai@users.noreply.github.com
Date:      2024-08-16T12:03:40Z
Fingerprint: 17f0efd70493cb29b8a261654491c4b5109b39cd:AWS_EC2,Lamda,RDS,IAM/RDS/terraform.tfvars:generic-api-key:7

4:16PM INF 103 commits scanned.
4:16PM INF scan completed in 2s
4:16PM WRN leaks found: 5

```

3 TruffleHog

is a secret discovery tool that scans files, repositories, commits, and Git history and can verify many detected credentials. Why: Helps find old or active leaked credentials.

trufflehog filesystem.

Save report: trufflehog filesystem . --json > trufflehog.json

```
ubuntu@ip-172-31-36-199:~/COTASK$ trufflehog filesystem .
🐷🐷 TruffleHog. Unearth your secrets. 🐷🐷

2026-07-27T06:13:48Z   info-0  trufflehog      running source {"source_manager_worker_id": "YcugB", "with_units": true}
Found unverified result 🐷🐷?
Detector Type: YoutubeApiKey
Decoder Type: PLAIN
Raw result: -thumbnail-with--CWD00BoeRV01Jw5QXUd3iw
File: Mastering-DevSecOps-Master/Day 20 AWS-Packer/README.md
Line: 3

Found unverified result 🐷🐷?
Detector Type: AzureStorage
Decoder Type: PLAIN
Raw result: yD05lCm7ud6VRLjHkjkceT3ysgEYedUn5SRC8jIU3PcNe/ZIocl+90BfRAU13QkF6CLfARX8IRA+ASta/NlOA==
Account_name: saikiransecops
File: Mastering-DevSecOps-Master/Day 30 AzureDevOps-Part-3/azure-pipelines.yml
Line: 164

Found unverified result 🐷🐷?
Detector Type: AzureStorage
Decoder Type: PLAIN
Raw result: yD05lCm7ud6VRLjHkjkceT3ysgEYedUn5SRC8jIU3PcNe/ZIocl+90BfRAU13QkF6CLfARX8IRA+ASta/NlOA==
Account_name: task
File: Mastering-DevSecOps-Master/Day 30 AzureDevOps-Part-3/azure-pipelines.yml
Line: 164

Found unverified result 🐷🐷?
Verification issue: lookup postgres on 127.0.0.53:53: server misbehaving
Detector Type: Postgres
Decoder Type: PLAIN
Raw result: postgres://testuser:testpass@postgres:5432
Sslmode: <unset>
Host: postgres:5432
Username: testuser
Database: testdb
```

```
Username: testuser
Database: testdb
File: jenkins-DeployECS UAT-POD/cicd_complete_guide 3 cicd tools dev prod.md
Line: 705

2026-07-27T06:13:57Z info-0 trufflehog finished scanning {"chunks": 8174, "bytes": 89469863, "verified_secrets": 0, "unverified_secrets": 4, "scan_duration": "9.363752394s", "trufflehog_version": "3.96.0", "verification_caching": {"Hits":0,"Misses":21,"HitsWasted":0,"AttemptsSaved":0,"VerificationTimeSpentMS":2220}}
ubuntu@ip-172-31-36-199:~/COTASK$ ls
'AWS_EC2,Lamda,RDS,IAM'          docker
AWS-VPC-Landing-Zone-Terraform-main  docker.txt
AZ                                ebs.tf
CICD_BlueGreen_EC2-main          gitlabci
'Day 29 AzureDevOps-Part-2'       install_jenkins.sh
Docker-Compose-Examples-master   'jenkins-DeployECS UAT-POD'
EC2podnewreagion.tf              jenkins-deploy-eks-via-eksctl-master
EC2prod.tf                       job
'EKS-Terraform-GitHub-Actions-master and Jenkins terraform module file and script'  kubernetes-yaml-templates-master
'IAM user and polices'           main.tf
LB.tf                             mongodb
Main.tf                           'multi-cloud-setup-main Githubaction'
Mastering-DevSecOps-Master        multi-cloud-setup-main.zip
README.md                         provider.tf
Redme.txt                         reportportal-master
Script                            s3.tf
Terraform-for-AWS-master          terraformmodule
TerraformScript-Co               'terraform EKS script.txt'
azure-ci-cd-pipeline-main         terraforme
backend.tf                       'terraformmyt-main AZURE'
blue-green-deploy-on-kubernetes-cluster-master  vpcmain.tf
compose-dev-env-main

ubuntu@ip-172-31-36-199:~/COTASK$ trufflehog filesystem . --json > trufflehog.json
{"level":"info-0","ts":"2026-07-27T06:16:50Z","logger":"trufflehog","msg":"running source","source_manager_worker_id":"NbSrR","with_units":true}
{"level":"info-0","ts":"2026-07-27T06:16:59Z","logger":"trufflehog","msg":"finished scanning","chunks":8175,"bytes":89473421,"verified_secrets":0,"unverified_secrets":7,"scan_duration":"9.002675138s","trufflehog_version":"3.96.0","verification_caching":{"Hits":8,"Misses":22,"HitsWasted":0,"AttemptsSaved":8,"VerificationTimeSpentMS":2300}}
ubuntu@ip-172-31-36-199:~/COTASK$
```

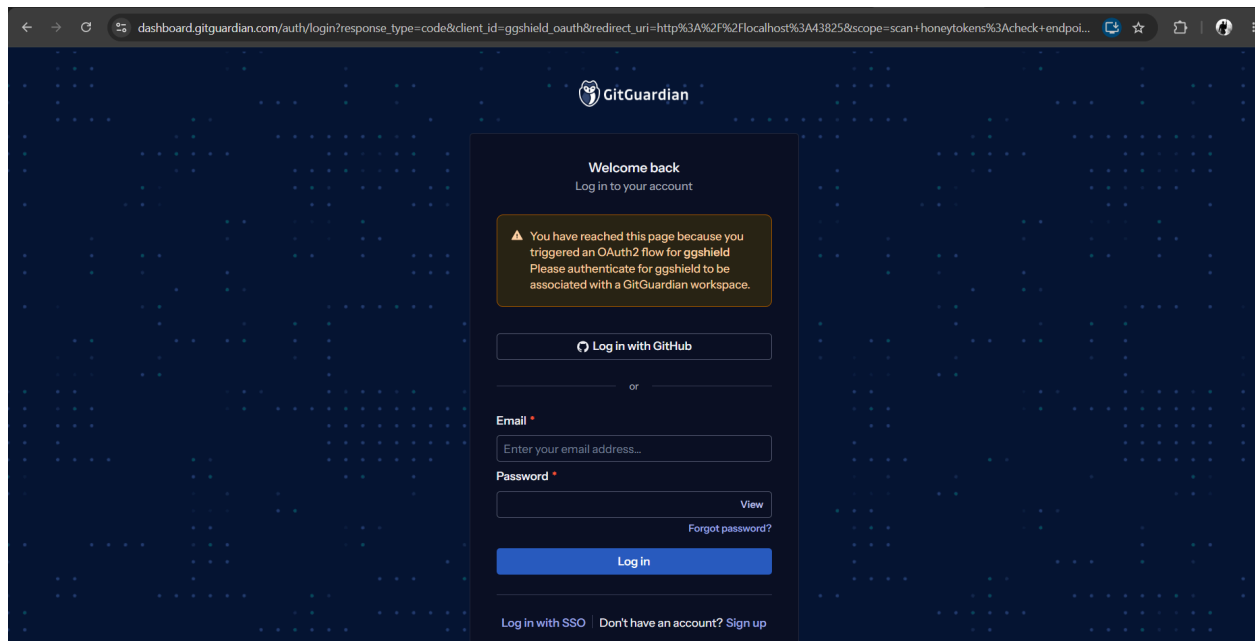
4 ggshield

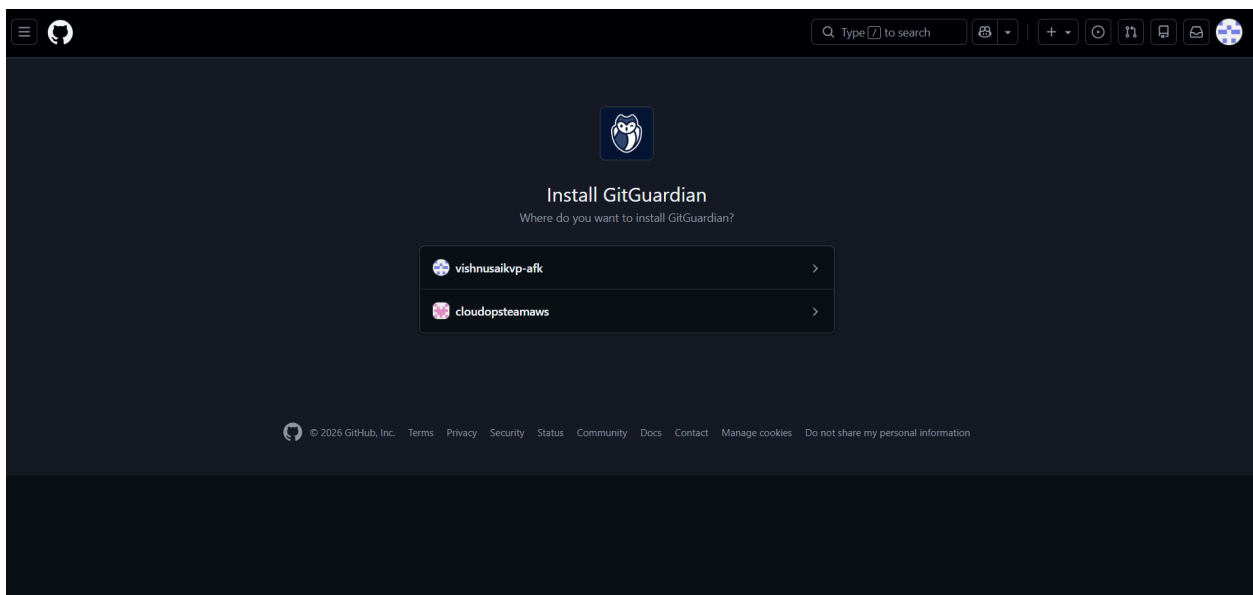
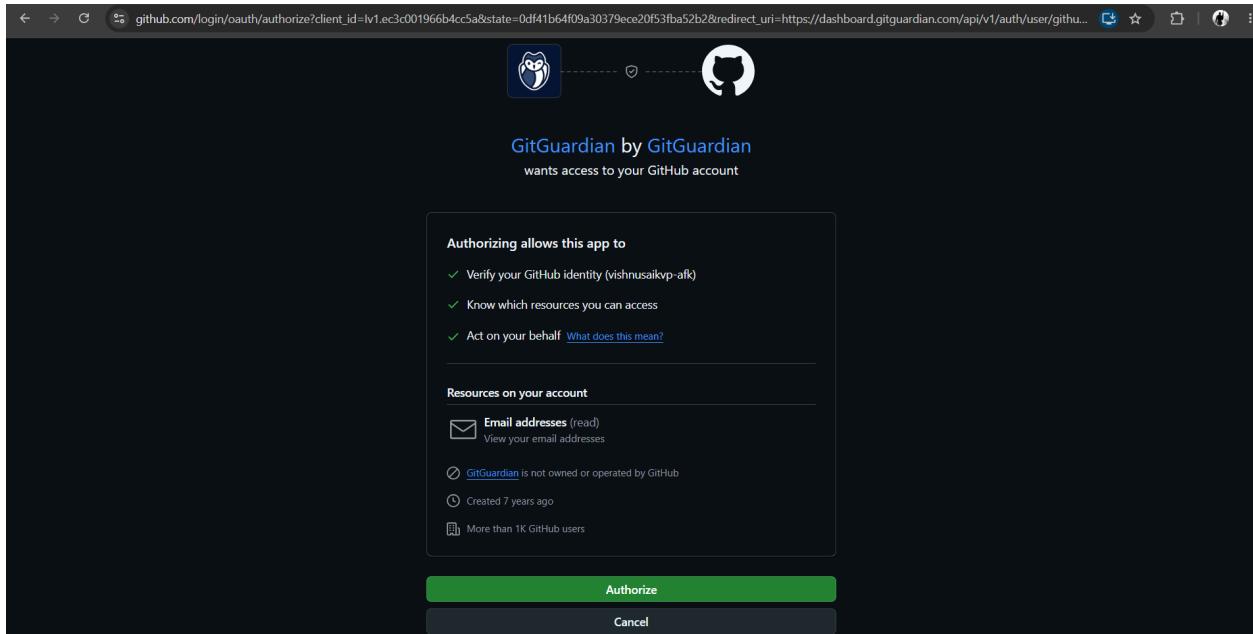
What: A secret detection tool from GitGuardian that scans code during **commit, push, and CI/CD**.

Why: Helps prevent secrets from entering Git repositories. ggshield itself is mainly a **CLI tool**, but it connects with the **GitGuardian web dashboard (UI)**. The UI provides a central place to view detected incidents, investigate secret details, track remediation status, manage teams, and monitor repositories.

ggshield auth login past the URL and open the webpage

```
ubuntu@ip-172-31-36-199:~/COTASK$ ggshield auth login
Complete the login process at:
https://dashboard.gitguardian.com/auth/login?response_type=code&client_id=ggshield_oauth&redirect_uri=http%3A%2F%2Flocalhost%3A43825&scope=scan+honeytokens%3Acheck+endpoints%3Asearch&state=257B%2522token_name%2522%253A%2520%2522ggshield%2520token%25202026-07-27%2522%252C%2520%2522lifetime%2522%253A%2520null%2527D&code_challenge=VgYdV0lnVID3lv48xQ0vtSgpRfCB4tbY1QhSpvYDF0g&code_challenge_method=S256&auth_mode=ggshield_login&utm_source=cli&utm_medium=login&utm_campaign=ggshield.
opening your web browser now...
```





Install on your organization cloudopsteamaws

for these repositories:

☒ **All repositories**

This applies to all current and future repositories owned by the resource owner.
Also includes public repositories (read-only).

☐ **Only select repositories**

Select at least one repository. Also includes public repositories (read-only).

with these permissions:

- ✓ **Read** access to code, members, and metadata
- ✓ **Read and write** access to checks, issues, organization hooks, and pull requests

User permissions

GitGuardian can also request users' permission to the following resources. These permissions will be requested and authorized on an individual-user basis.

- ✓ **Read** access to email addresses

Install

[Cancel](#)

Next, you'll be directed to the GitHub App's site to complete setup.

5 Betterleaks

Betterleaks is a secret-scanning tool. Its job is to search source code and Git repositories for credentials that should not be stored in code.

What: A security tool that **scans code to find leaked secrets** like passwords, API keys, tokens, and cloud credentials.

Why: Helps find credentials that developers accidentally put inside the code before they become a security problem.

Where: Used on **source code, Git repositories, and CI/CD pipelines.**

Example: If a developer puts an AWS key or database password in the code, Betterleaks can detect it.

Main use: Find secrets hidden in code.

Scan current files/directories

betterleaks dir . -v

Git-aware repository scan

betterleaks git . -v

Scan current filesystem for secrets

trufflehog filesystem .

Scan Git repository and commit history

trufflehog git file://\$(pwd)

```
ubuntu@ip-172-31-36-199:~/COTASK$ # 1. Betterleaks - current directory/files
betterleaks dir . -v

# 2. Betterleaks - Git repository
betterleaks git . -v

# 3. TruffleHog - current directory/files
trufflehog filesystem .

# 4. TruffleHog - complete Git history
trufflehog git file://$(pwd)

○
○
●
○ betterleaks dev
-
hashicorp-tf-password-○
8 | password = "username123"
   |          ~~~~~
attributes:
  path ..... ./Terraform-for-AWS-master/Non-Modularized/Simple-RDS-Instance/rds.tf
  resource ..... fs.content
○
S:46PM WRN error reading archive error="zip: not a valid zip file" path=./Terraform-for-AWS-master/Non-Modularized/Lambda-Function/code/hello.zip!hello.zip
-
generic-api-key-○
7 | password = "jvasccqte7yibxwyst2i2db"
   |          ~~~~~
attributes:
  path ..... ./TerraformScript-Co/AWS/RDS/terraform.tfvars
  resource ..... fs.content
○
-
mongodb-connection-string-○
273 | "Match": "mongodb://{MONGO_USER}:{MONGO_PASS}@127.0.0.1:27017/admin\"",
     |          ~~~~~
attributes:
  path ..... ./report.json
  resource ..... fs.content
```

```

○
○
●
○ betterleaks dev
—mongodb-connection-string—○

```

```
40 MONGO_URI      = f"mongodb://{MONGO_USER}:{MONGO_PASS}@127.0.0.1:27017/admin"
attributes:
git.author_email ..... 78133546+0000sai@users.noreply.github.com
git.author_name ..... vishnu sai
git.date ..... 2025-09-29T15:18:56Z
git.message ..... Create cleanupscripts3backup.py
git.platform ..... github
git.remote_url ..... https://github.com/0000sai/COTASK
git.sha ..... cb03f9de062769ede383b669cc66b363bc4e7a5
path ..... Script/phy/cleanupscripts3backup.py
resource ..... git_patch_content
url ..... https://github.com/0000sai/COTASK/blob/cb03f9de062769ede383b669cc66b363bc4e7a5/Script/phy/cleanupscripts3backup.py#L40
```

```
40 MONGO_URI      = f"mongodb://{MONGO_USER}:{MONGO_PASS}@127.0.0.1:27017/admin"
attributes:
git.author_email ..... 78133546+0000sai@users.noreply.github.com
git.author_name ..... vishnu sai
git.date ..... 2025-09-29T15:22:59Z
git.message ..... Create DBcleanups3.py
git.platform ..... github
git.remote_url ..... https://github.com/0000sai/COTASK
git.sha ..... a725b9b86d3569624d71125469ce1414cc2d80d
path ..... Script/phy/Cleanupscript/DBcleanups3.py
resource ..... git.patch_content
url ..... https://github.com/0000sai/COTASK/blob/a725b9b86d3569624d71125469ce1414cc2d80d/Script/phy/Cleanupscript/DBcleanups3.py#L40
```

```
generic-api-key=0
```

5:46PM WRN leaks found: 9
🔗🔗🔗 TruffleHog. Unearth your secrets. 🔗🔗🔗

```
2026-07-27T17:46:39Z    info-0    trufflehog    running source {"source_manager_worker_id": "foNk8", "with_units": true}
```

Found unverified result   ?

Detector Type: YoutubeApiKey

Decoder Type: PLAIN

```
Raw result: -thumbnail-with--CWD00BoeRVO1Jw5QXUd3iw
```

File: Mastering-DevSecOps-Master/Day 20 AWS-Packer/README.md

Line: 3

Found unverified result ?

Detector Type: AzureStorage

Decoder Type: PLAIN

Raw result: yD051Cm7ud6VRLjHkjikceT3ysgEYeDUn5SRC8jIU3PcNe/ZIoc1+90BfRAU13QkF6CLfARX8IRA+AsTA/N10A==

```
Account_name: task
```

File: Mastering-DevSecOps-Master/Day 30 AzureDevOps-Part-3/azure-pipelines.yml

Line: 164

Found unverified result 🤖🔗?

Detector Type: AzureStorage

Decoder Type: PLAIN

Raw result: yD051Cm7ud6VRLjHkjikceT3ysgEYeDUn5SRC8jIU3PcNe/ZIoc1+90BfRAU13QkF6CLfARX8IRA+AStA/N10A==

Account_name: saikiransecops

File: Mastering-DevSecOps-Master/Day 30 AzureDevOps-Part-3/azure-pipelines.yml

Line: 164

Found unverified result 0 0 ?

```
Verification issue: lookup postgres on 127.0.0.53:53: server misbehaving
```

Detector Type: Postgres

Decoder Type: PLAIN

```
Raw result: postgres://testuser:testpass@postgres:5432
```

Host: postgres:5432

```
Username: testuser
```

Database: testdb

```
Sslmode: <unset>
```

File: jen

1000

Found unverified result ?

Verification issue: look

Detector Type: Postgres
Reader Type: ESCAPED_UNICODE

```
Decoder Type: ESCAPED_UNICODE
Raw result: postgres://testuser:testpass@postgres:5432" "Row4/3": "postgres:5432"
```

Raw result: postgresql
Calmed: success

```
Host: postgres:5432" "RawV2": "postgres:5432"
```

```
Host: postgres:543.  
Username: testuser
```

```
Sqlmode: <unset>
Host: postgres:5432
Username: testuser
Database: testdb
Commit: a134781f035ad5234ef0e0fa289fa86403d2a2ae
Email: vishnu sai <78133546+0000sai@users.noreply.github.com>
File: jenkins-DeployECS UAT-POD/cicd_complete_guide 3 cicd tools dev prod.md
Line: 705
Repository: file:///home/ubuntu/COTASK
Timestamp: 2025-09-09 15:50:56 +0000

Found unverified result 0/0 ?
Detector Type: YoutubeApiKey
Decoder Type: PLAIN
Raw result: -thumbnail--with--CnID008oeRV01jw5QXud3iw
Commit: 5fb891adc7813544003728a065333d63b2a9aed9f
Email: 0000sai <78133546+0000sai@users.noreply.github.com>
File: Mastering-DevSecOps-Master/Day 20 AWS-Packer/README.md
Line: 3
Repository: file:///home/ubuntu/COTASK
Repository_local_path: /tmp/trufflehog-36613-896477596
Timestamp: 2025-02-14 07:44:23 +0000

Found unverified result 0/0 ?
Detector Type: AzureStorage
Decoder Type: PLAIN
Raw result: y0051Cm7ud6VRLjHkjkceT3ysgEYeDUn5SRC8jIU3PcNe/ZIoc1+90BfRAU13QkF6CLfARX8IRA+ASTa/N10A==
Account_name: saikiransecops
Commit: dc3a39571642672b0985d61f26be2a913b21ccf9
Email: 0000sai <78133546+0000sai@users.noreply.github.com>
File: Mastering-DevSecOps-Master/Day 30 AzureDevOps-Part-3/azure-pipelines.yml
Line: 164
Repository: file:///home/ubuntu/COTASK
Timestamp: 2025-02-14 07:56:44 +0000

Found unverified result 0/0 ?
Detector Type: AzureStorage
Decoder Type: PLAIN
Raw result: yD051Cm7ud6VRLjHkjkceT3ysgEYeDUn5SRC8jIU3PcNe/ZIoc1+90BfRAU13QkF6CLfARX8IRA+ASTa/N10A==
Account_name: task
Commit: dc3a39571642672b0985d61f26be2a913b21ccf9
Email: 0000sai <78133546+0000sai@users.noreply.github.com>
File: Mastering-DevSecOps-Master/Day 30 AzureDevOps-Part-3/azure-pipelines.yml
Line: 164
Repository: file:///home/ubuntu/COTASK
Timestamp: 2025-02-14 07:56:44 +0000

2026-07-27T17:46:55Z info=0 trufflehog finished scanning {"chunks": 3228, "bytes": 21437449, "Verified_secrets": 0, "Unverified_secrets": 4, "scan_duration":
"3.885211429s", "trufflehog_version": "3.96.0", "Verification_caching": {"Hits": 2, "Misses": 25, "HitsWasted": 0, "AttemptsSaved": 2, "VerificationTimeSpentMS": 3363}}
```

6 Semgrep

What: A SAST/code analysis tool that scans source code for security vulnerabilities and insecure coding patterns.

Why: Helps detect issues such as **SQL injection**, **XSS**, **command injection**, and **insecure code** before deployment.

1. General Automatic SAST Scan

Automatically detects project languages and applies relevant Semgrep rules.

semgrep scan --config auto .

2. Security Audit Scan

Checks source code for security vulnerabilities and insecure coding patterns.

semgrep scan --config p/security-audit .

3. OWASP Top 10 Scan

Focuses on vulnerabilities related to the OWASP Top 10.

semgrep scan --config p/owasp-top-ten .

4. CI/CD Security Gate

Runs automatic SAST scanning and returns a non-zero exit code when

blocking findings are detected, allowing the CI/CD pipeline to fail.

semgrep scan --config auto --error .

```
ubuntu@ip-172-31-36-199:~/COTASK$ # General automatic SAST scan
semgrep scan --config auto .

# Security audit
semgrep scan --config p/security-audit .

# OWASP-focused scan
semgrep scan --config p/owasp-top-ten .
METRICS: Using configs from the Registry (like --config=p/ci) reports pseudonymous rule metrics to semgrep.dev.
To disable Registry rule metrics, use "--metrics=off".
Using configs only from local files (like --config=xyz.yml) does not enable metrics.

More information: https://semgrep.dev/docs/metrics

Rules downloaded from https://semgrep.dev/c/auto failed to parse.
This is likely because rules have been added that use functionality introduced in later versions of semgrep.
Please upgrade to latest version of semgrep (see https://semgrep.dev/docs/upgrading/) and try again.

semgrep error: Invalid rule schema
--> None:1
1 | a: b
  | ^^^

'MEDIUM' is not one of ['ERROR', 'WARNING', 'INFO', 'INVENTORY', 'EXPERIMENT']

ERROR invalid configuration file found (1 configs were invalid)

Scan Status
Scanning 1248 files (only git-tracked) with 225 Code rules:

CODE RULES


| Language    | Rules | Files | Origin    | Rules |
|-------------|-------|-------|-----------|-------|
| <multilang> | 18    | 1214  | Community | 225   |
| terraform   | 3     | 504   |           |       |
| json        | 1     | 46    |           |       |
| python      | 77    | 21    |           |       |
| js          | 20    | 21    |           |       |
| dockerfile  | 1     | 12    |           |       |
| java        | 52    | 8     |           |       |
| go          | 28    | 8     |           |       |
| ts          | 20    | 4     |           |       |
| ruby        | 16    | 1     |           |       |


```

'MEDIUM' is not one of ['ERROR', 'WARNING', 'INFO', 'INVENTORY', 'EXPERIMENT']

ERROR invalid configuration file found (1 configs were invalid)

Scan Status

Scanning 1248 files (only git-tracked) with 225 Code rules:

CODE RULES

Language	Rules	Files	Origin	Rules
<multilang>	18	1214	Community	225
terraform	3	504		
json	1	46		
python	77	21		
js	20	21		
dockerfile	1	12		
java	52	8		
go	28	8		
ts	20	4		
ruby	16	1		

SUPPLY CHAIN RULES

Sign in with 'semgrep login' and run
semgrep ci to find dependency vulnerabilities and
advanced cross-file findings.

PROGRESS

100% 0:00:10

Warning: 2 timeout error(s) in azure-ci-cd-pipeline-main/assets/js/jquery.js when running the following rules:
[javascript.lang.security.audit.unknown-value-with-script-tag.unknown-value-with-script-tag,
javascript.lang.security.detect-eval-with-expression.detect-eval-with-expression]

12 Code Findings

EKS-Terraform-GitHub-Actions-master and Jenkins terraform module file and script/module/eks.tf
terraform.lang.security.eks-public-endpoint-enabled.eks-public-endpoint-enabled
The vpc_config resource inside the eks cluster has not explicitly disabled public endpoint

12 Code Findings

EKS-Terraform-GitHub-Actions-master and Jenkins terraform module file and script/module/eks.tf
terraform.lang.security.eks-public-endpoint-enabled.eks-public-endpoint-enabled
The vpc_config resource inside the eks cluster has not explicitly disabled public endpoint
access
Details: <https://sg.run/A1bg>

```
1: resource "aws_eks_cluster" "eks" {
```

Script/phy/EC2 Clean Cpu Memory Notification/Server Montring cpu memroy alert Slack Teams iam logs.py

python.lang.security.audit.subprocess-shell-true.subprocess-shell-true

Found 'subprocess' function 'check_output' with 'shell=True'. This is dangerous because this
call will spawn the command using a shell process. Doing so propagates current shell
settings and variables, which makes it much easier for a malicious actor to execute
commands. Use 'shell=False' instead.
Details: <https://sg.run/392w>

AutoFix False

```
136: return subprocess.check_output(cmd, shell=True, text=True)
```

Script/phy/EC2 Clean Cpu Memory Notification/ec2cleanup (1).py

python.lang.security.audit.subprocess-shell-true.subprocess-shell-true

Found 'subprocess' function 'check_output' with 'shell=True'. This is dangerous because this
call will spawn the command using a shell process. Doing so propagates current shell
settings and variables, which makes it much easier for a malicious actor to execute
commands. Use 'shell=False' instead.
Details: <https://sg.run/392w>

AutoFix False

```
99: return subprocess.check_output(cmd, shell=True, text=True)
```

Script/phy/EC2 Clean Cpu Memory Notification/server cleanup alert slackTeams (1).py

python.lang.security.audit.subprocess-shell-true.subprocess-shell-true

Found 'subprocess' function 'check_output' with 'shell=True'. This is dangerous because this
call will spawn the command using a shell process. Doing so propagates current shell
settings and variables, which makes it much easier for a malicious actor to execute
commands. Use 'shell=False' instead.
Details: <https://sg.run/392w>

AutoFix False

```
110: return subprocess.check_output(cmd, shell=True, text=True)
```

Script/phy/Server Montring cpu memroy alert Slack Teams iam logs.py

python.lang.security.audit.subprocess-shell-true.subprocess-shell-true

Found 'subprocess' function 'check_output' with 'shell=True'. This is dangerous because this